

[MS-PKAP]:

Public Key Authentication Protocol

Intellectual Property Rights Notice for Open Specifications Documentation

- **Technical Documentation.** Microsoft publishes Open Specifications documentation (“this documentation”) for protocols, file formats, data portability, computer languages, and standards support. Additionally, overview documents cover inter-protocol relationships and interactions.
- **Copyrights.** This documentation is covered by Microsoft copyrights. Regardless of any other terms that are contained in the terms of use for the Microsoft website that hosts this documentation, you can make copies of it in order to develop implementations of the technologies that are described in this documentation and can distribute portions of it in your implementations that use these technologies or in your documentation as necessary to properly document the implementation. You can also distribute in your implementation, with or without modification, any schemas, IDLs, or code samples that are included in the documentation. This permission also applies to any documents that are referenced in the Open Specifications documentation.
- **No Trade Secrets.** Microsoft does not claim any trade secret rights in this documentation.
- **Patents.** Microsoft has patents that might cover your implementations of the technologies described in the Open Specifications documentation. Neither this notice nor Microsoft's delivery of this documentation grants any licenses under those patents or any other Microsoft patents. However, a given Open Specifications document might be covered by the Microsoft [Open Specifications Promise](#) or the [Microsoft Community Promise](#). If you would prefer a written license, or if the technologies described in this documentation are not covered by the Open Specifications Promise or Community Promise, as applicable, patent licenses are available by contacting iplg@microsoft.com.
- **License Programs.** To see all of the protocols in scope under a specific license program and the associated patents, visit the [Patent Map](#).
- **Trademarks.** The names of companies and products contained in this documentation might be covered by trademarks or similar intellectual property rights. This notice does not grant any licenses under those rights. For a list of Microsoft trademarks, visit www.microsoft.com/trademarks.
- **Fictitious Names.** The example companies, organizations, products, domain names, email addresses, logos, people, places, and events that are depicted in this documentation are fictitious. No association with any real company, organization, product, domain name, email address, logo, person, place, or event is intended or should be inferred.

Reservation of Rights. All other rights are reserved, and this notice does not grant any rights other than as specifically described above, whether by implication, estoppel, or otherwise.

Tools. The Open Specifications documentation does not require the use of Microsoft programming tools or programming environments in order for you to develop an implementation. If you have access to Microsoft programming tools and environments, you are free to take advantage of them. Certain Open Specifications documents are intended for use in conjunction with publicly available standards specifications and network programming art and, as such, assume that the reader either is familiar with the aforementioned material or has immediate access to it.

Support. For questions and support, please contact dochelp@microsoft.com.

Revision Summary

Date	Revision History	Revision Class	Comments
6/30/2015	1.0	New	Released new document.
10/16/2015	1.0	None	No changes to the meaning, language, or formatting of the technical content.
7/14/2016	1.0	None	No changes to the meaning, language, or formatting of the technical content.
6/1/2017	2.0	Major	Significantly changed the technical content.
9/15/2017	3.0	Major	Significantly changed the technical content.
12/1/2017	3.0	None	No changes to the meaning, language, or formatting of the technical content.
9/12/2018	4.0	Major	Significantly changed the technical content.
4/7/2021	5.0	Major	Significantly changed the technical content.
4/23/2024	6.0	Major	Significantly changed the technical content.

Table of Contents

1	Introduction	5
1.1	Glossary	5
1.2	References	5
1.2.1	Normative References	6
1.2.2	Informative References	6
1.3	Overview	6
1.4	Relationship to Other Protocols	7
1.5	Prerequisites/Preconditions	7
1.6	Applicability Statement	7
1.7	Versioning and Capability Negotiation	7
1.8	Vendor-Extensible Fields	7
1.9	Standards Assignments.....	7
2	Messages.....	8
2.1	Transport	8
2.2	Common Data Types	8
2.2.1	Complex Types.....	8
2.2.1.1	Client Token	8
2.2.1.2	Client Token JWS Headers.....	8
3	Protocol Details	10
3.1	Client Details	10
3.1.1	Abstract Data Model.....	10
3.1.2	Timers	10
3.1.3	Initialization.....	10
3.1.4	Higher-Layer Triggered Events	10
3.1.5	Message Processing Events and Sequencing Rules	10
3.1.5.1	Initial Request	10
3.1.5.1.1	Request	10
3.1.5.1.2	Response	11
3.1.5.1.3	Processing Details	11
3.1.5.2	Issuer based certificate challenge response	11
3.1.5.2.1	Request	11
3.1.5.2.2	Response	12
3.1.5.2.3	Processing Details	12
3.1.5.3	Thumbprint based certificate challenge response	13
3.1.5.3.1	Request	13
3.1.5.3.2	Response	13
3.1.5.3.3	Processing Details	13
3.1.6	Timer Events.....	14
3.1.7	Other Local Events.....	14
3.2	Server Details.....	14
3.2.1	Abstract Data Model.....	14
3.2.2	Timers	14
3.2.3	Initialization.....	14
3.2.4	Higher-Layer Triggered Events	14
3.2.5	Message Processing Events and Sequencing Rules	14
3.2.5.1	Issuer based certificate challenge.....	15
3.2.5.1.1	Request	15
3.2.5.1.2	Response	15
3.2.5.1.3	Processing Details	15
3.2.5.2	Thumbprint based certificate challenge	15
3.2.5.2.1	Request	16
3.2.5.2.2	Response	16
3.2.5.2.3	Processing Details	16

3.2.5.3	Challenge response processing	16
3.2.5.3.1	Request	16
3.2.5.3.2	Response	16
3.2.5.3.3	Processing Details	16
3.2.6	Timer Events.....	17
3.2.7	Other Local Events.....	17
4	Protocol Examples	18
4.1	Interactive Request	18
4.1.1	Client Request.....	18
4.1.2	Server Challenge Response	18
4.1.3	Client Response.....	18
4.2	OAuth Token Request	19
4.2.1	Client Refresh Token Request.....	19
4.2.2	Server Challenge Response	19
4.2.3	Client Response.....	20
5	Security	22
5.1	Security Considerations for Implementers	22
5.2	Index of Security Parameters	22
6	Appendix A: Product Behavior	23
7	Change Tracking.....	24
8	Index.....	25

1 Introduction

The Public Key Authentication Protocol (PKAP) provides a method for **HTTP** clients to prove possession of a private key to a web server without having to rely on client **Transport Layer Security (TLS)** support [\[RFC4346\]](#) from the underlying platform.

Sections 1.5, 1.8, 1.9, 2, and 3 of this specification are normative. All other sections and examples in this specification are informative.

1.1 Glossary

This document uses the following terms:

Active Directory Federation Services (AD FS): A Microsoft implementation of a federation services provider, which provides a security token service (STS) that can issue security tokens to a caller using various protocols such as WS-Trust, WS-Federation, and Security Assertion Markup Language (SAML) version 2.0.

base64 encoding: A binary-to-text encoding scheme whereby an arbitrary sequence of bytes is converted to a sequence of printable ASCII characters, as described in [\[RFC4648\]](#).

Hypertext Transfer Protocol (HTTP): An application-level protocol for distributed, collaborative, hypermedia information systems (text, graphic images, sound, video, and other multimedia files) on the World Wide Web.

JSON web signature (JWS): A mechanism that uses JavaScript Object Notation (JSON) data structures to represent signed content.

JSON Web Token (JWT): A string representing a set of claims as a JSON object that is encoded in a **JWS** or JWE, enabling the claims to be digitally signed or integrity protected with a Message Authentication Code (MAC) and/or encrypted. For more information, see [\[RFC7519\]](#).

nonce: A number that is used only once. This is typically implemented as a random number large enough that the probability of number reuse is extremely small. A nonce is used in authentication protocols to prevent replay attacks. For more information, see [\[RFC2617\]](#).

Secure Sockets Layer (SSL): A security protocol that supports confidentiality and integrity of messages in client and server applications that communicate over open networks. SSL supports server and, optionally, client authentication using X.509 certificates [\[X509\]](#) and [\[RFC5280\]](#). SSL is superseded by **Transport Layer Security (TLS)**. TLS version 1.0 is based on SSL version 3.0 [\[SSL3\]](#).

Transport Layer Security (TLS): A security protocol that supports confidentiality and integrity of messages in client and server applications communicating over open networks. TLS supports server and, optionally, client authentication by using X.509 certificates (as specified in [\[X509\]](#)). TLS is standardized in the IETF TLS working group.

MAY, SHOULD, MUST, SHOULD NOT, MUST NOT: These terms (in all caps) are used as defined in [\[RFC2119\]](#). All statements of optional behavior use either MAY, SHOULD, or SHOULD NOT.

1.2 References

Links to a document in the Microsoft Open Specifications library point to the correct section in the most recently published version of the referenced document. However, because individual documents in the library are not updated at the same time, the section numbers in the documents may not match. You can confirm the correct section numbering by checking the [Errata](#).

1.2.1 Normative References

We conduct frequent surveys of the normative references to assure their continued availability. If you have any issue with finding a normative reference, please contact dochelp@microsoft.com. We will assist you in finding the relevant information.

[IETFDRAFT-JWA-36] Jones, M., "JSON Web Algorithms (JWA)", draft-ietf-jose-json-web-algorithms-36, October 2014, <https://tools.ietf.org/html/draft-ietf-jose-json-web-algorithms-36>

[IETFDRAFT-JWS] Internet Engineering Task Force (IETF), "JSON Web Signature (JWS)", draft-ietf-jose-json-web-signature-10, April 2013, <http://tools.ietf.org/html/draft-ietf-jose-json-web-signature-10>

[IETFDRAFT-JWT-LATEST] Bradley, J., Jones, M., and Sakimura, N., "JSON Web Token (JWT)", draft-ietf-oauth-json-web-token-32, December 2014, <https://datatracker.ietf.org/doc/html/draft-ietf-oauth-json-web-token-32>

Note Links to all 32+ versions including RFC7519

[RFC2119] Bradner, S., "Key words for use in RFCs to Indicate Requirement Levels", BCP 14, RFC 2119, March 1997, <https://www.rfc-editor.org/info/rfc2119>

[RFC2459] Housley, R., Ford, W., Polk, W., and Solo, D., "Internet X.509 Public Key Infrastructure Certificate and CRL Profile", RFC 2459, January 1999, <https://www.rfc-editor.org/info/rfc2459>

[RFC2616] Fielding, R., Gettys, J., Mogul, J., et al., "Hypertext Transfer Protocol -- HTTP/1.1", RFC 2616, June 1999, <https://www.rfc-editor.org/info/rfc2616>

[RFC2818] Rescorla, E., "HTTP Over TLS", RFC 2818, May 2000, <https://www.rfc-editor.org/info/rfc2818>

[RFC4158] Cooper, M., Dzambasow, Y., Hesse, P., et al., "Internet X.509 Public Key Infrastructure: Certification Path Building", RFC 4158, September 2005, <https://www.rfc-editor.org/info/rfc4158>

1.2.2 Informative References

[ISO8601] ISO, "Data elements and interchange formats - Information interchange - Representation of dates and times", ISO 8601:2004, December 2004, http://www.iso.org/iso/iso_catalogue/catalogue_tc/catalogue_detail.htm?csnumber=40874

Note There is a charge to download the specification.

[RFC4346] Dierks, T., and Rescorla, E., "The Transport Layer Security (TLS) Protocol Version 1.1", RFC 4346, April 2006, <https://www.rfc-editor.org/info/rfc4346>

[RFC6265] Barth, A., "HTTP State Management Mechanism", RFC 6265, April 2011, <https://tools.ietf.org/html/rfc6265>

1.3 Overview

One of the most common practices to validate the proof of possession of a secret on the client in an **HTTP** transaction is to use **Secure Sockets Layer (SSL)/Transport Layer Security (TLS)** client authentication. Although this works in many cases, using this method has the following drawbacks.

- SSL/TLS client authentication is not supported on many HTTP client implementations. There is no simple way for a client application relying on the platform to prove possession of private keys for X509 certificates [\[RFC4158\]](#).

- It is not convenient to use SSL/TLS client authentication when the service needs to validate proof of possession of multiple keys. With SSL/TLS client authentication, a dynamic renegotiation of client certificates is required after verifying proof of possession of each key. Some server implementations do not support this type of dynamic renegotiation of certificates because the challenge criteria are statically configured on the server.

This protocol provides a way for client applications written on any HTTP client stack to participate in a message-based protocol. A client application uses this protocol at the application layer to prove that its possession of private keys of X509 certificates fits the criteria configured on the server.

To participate in this protocol, the HTTP client application should enable HTTP cookie handling [\[RFC6265\]](#). The server can use HTTP cookies (that the server can validate and use later) to save any state during the protocol interaction.

1.4 Relationship to Other Protocols

The Public Key Authentication Protocol depends on HTTP [\[RFC2616\]](#).

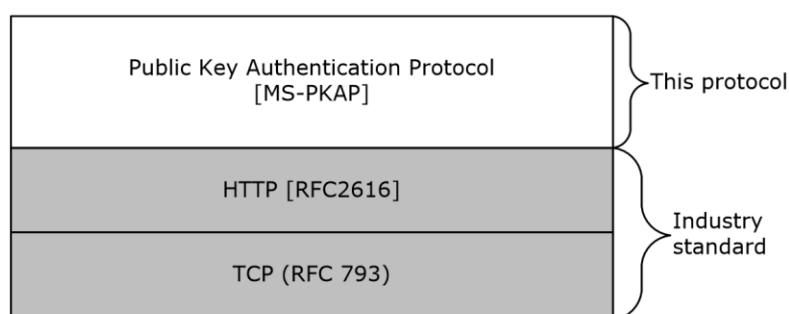


Figure 1: Protocol dependency

1.5 Prerequisites/Preconditions

All exchanges in this protocol happen over an HTTPS channel [\[RFC2818\]](#).

1.6 Applicability Statement

The Public Key Authentication Protocol was designed to provide an alternative means for clients to perform device authentication with **Active Directory Federation Services (AD FS)**. Using this alternative means for device authentication is applicable when a client cannot rely on the client **TLS** mechanism offered by its underlying operating system platform.

1.7 Versioning and Capability Negotiation

Supported Transports: The Public Key Authentication Protocol (PKAP) supports only HTTP.

1.8 Vendor-Extensible Fields

None.

1.9 Standards Assignments

None.

2 Messages

2.1 Transport

The HTTP protocol [\[RFC2616\]](#) MUST be used as the transport.

2.2 Common Data Types

2.2.1 Complex Types

The following table summarizes the set of complex type definitions that are included in this specification.

Complex type	Section	Description
Client Token	2.2.1.1	The token that is presented to the server as part of the challenge response.
Client Token JWS Headers	2.2.1.2	Data that is included as part of the headers during signing.

2.2.1.1 Client Token

This type represents the token that needs to be presented to the server as part of the challenge response.

```
{
  "aud" : "<server-endpoint>",
  "iat" : "<creation-timestamp>",
  "nonce" : "<server-challenge-nonce>"
}
```

server-endpoint: The service endpoint that this token is meant for. It is the full URL of the service endpoint that responded with the challenge to the initial request.

creation-timestamp: The timestamp at the client when the token was created. It is represented in Unix time [\[ISO8601\]](#) as a 64-bit signed integer.

server-challenge-nonce: A **nonce** that is issued as part of the server challenge.

2.2.1.2 Client Token JWS Headers

This type represents data that is included as part of the headers during **JSON Web Signature (JWS)** signing [\[IETFDRAFT-JWS\]](#).

```
{
  "alg" : "<signing-algorithm>",
  "typ" : "<token-type>",
  "x5c" : "<signing-cert>"
}
```


signing-algorithm: The algorithm that will be used for signing, as specified in the JWS specification ([IETFdraft-jws] section 4.1.1). It is a hint to the server regarding how the signature was generated. The appropriate value defined in the algorithm table of the JSON Web Algorithms specification ([\[IETFdraft-jwa-36\]](#) section 3.1) is used for this purpose.

token-type: Set to "jwt" in order to signify that the signed content is a **JSON Web Token (JWT)** [\[IETFdraft-jwt-latest\]](#).

signing-cert: The X509 certificate [\[RFC4158\]](#) used to sign the Client Token (without the private key), as a **base64-encoded** string.

3 Protocol Details

3.1 Client Details

3.1.1 Abstract Data Model

None.

3.1.2 Timers

None.

3.1.3 Initialization

None.

3.1.4 Higher-Layer Triggered Events

A client that is capable of using the Public Key Authentication Protocol (PKAP) MUST always make requests to an **HTTP** server that conform to the "Initial Request" (section [3.1.5.1](#)), regardless of proof of possession of keys that might be required by the server it is trying to access.

3.1.5 Message Processing Events and Sequencing Rules

The behavior of the client can be divided into its actions on the following processing events.

Event	Description
Initial request	The initial request that the client makes to indicate to the server that it supports PKAP. The initial request can take one of two forms, depending on whether the client prefers to set HTTP headers or user agent strings.
Response for issuer based certificate challenge	The client's response when the server challenges for proof of possession of the private key of any certificate issued by one of a given set of issuers.
Response for thumbprint based certificate challenge	The client's response when the server challenges for proof of possession of the private key of a specific certificate.

3.1.5.1 Initial Request

When the client makes a request to the service's endpoint that might require verification of proof of possession of an X509 certificate [\[RFC4158\]](#), the request follows the rules defined in the following sections.

3.1.5.1.1 Request

If the client is capable and prefers to add **HTTP** headers, it MUST insert an HTTP header into the HTTP request that it is sending to the server. This header indicates that the server should use PKAP for client authentication instead of a traditional mechanism (such as **SSL/TLS** client authentication).

This HTTP header is defined as follows.

Header Name	Value
x-ms-PKeyAuth	1.0

Alternatively, if the client is not capable or prefers not to add HTTP headers, the client can choose to pass the string "PKeyAuth/1.0" along with its User-Agent header [\[RFC2616\]](#).

The requests with the x-ms-PKeyAuth header and the requests with the User-Agent header are semantically equivalent.

All other parts of the HTTP request (HTTP method, contents of the body, and so on) are specific to the client and the service application.

3.1.5.1.2 Response

The server that supports PKAP responds to this message as specified in section [3.2.5.1](#) or section [3.2.5.2](#).

3.1.5.1.3 Processing Details

Upon receiving a response as specified in section [3.2.5.1](#), the client MUST respond to the challenge as detailed in section [3.1.5.2](#).

Upon receiving a response as specified in section [3.2.5.2](#), the client MUST respond to the challenge as detailed in section [3.1.5.3](#).

3.1.5.2 Issuer based certificate challenge response

The server's response is a challenge for proof of possession of a private key for a certificate that is acceptable to the server, as described in section [3.2.5.1](#). The server's challenge from section 3.2.5.1 is converted into an [Issuer based certificate challenge], and a signed **JWT** token is created on the client from the [Issuer based certificate challenge], as defined in the processing details (section [3.1.5.2.3](#)). The client then responds to the server with a challenge response as defined in section [3.1.5.2.1](#).

Note that an [Issuer based certificate challenge], which is used only locally for message processing, is a tuple with the following definition.

```
[Issuer based certificate challenge] =
[
  SubmitUrl, string;
  CertAuthorities, string;
  ServerContext, string;
  Nonce, string
]
```

3.1.5.2.1 Request

In response to the server's challenge, which is specified in section [3.2.5.1](#), the client responds to the server by making an **HTTP** request to the server as follows.

HTTP Request parameter	Value
Method	GET
URL	[Issuer based certificate challenge].SubmitUrl
Header: "Authorization"	PKeyAuth AuthToken="<Signed-JWT>", Context="[Issuer based

HTTP Request parameter	Value
	certificate challenge].ServerContext"

Signed-JWT: A Client Token (section [2.2.1.1](#)) that was generated and signed using **JWS**, as specified in the processing details (section [3.1.5.2.3](#)).

3.1.5.2.2 Response

See section [3.2.5.3](#).

3.1.5.2.3 Processing Details

The client processes the server's issuer based certificate challenge in the following manner.

1. The client converts the server's challenge into an [Issuer based certificate challenge] as follows.

[Issuer based certificate challenge] name	Value
SubmitUrl	<Submit-url> (section 3.2.5.1.2)
CertAuthorities	<cert-authorities> (section 3.2.5.1.2)
ServerContext	<Server-state> (section 3.2.5.1.2)
Nonce	<Challenge-nonce> (section 3.2.5.1.2)

2. The client forms a Client Token (section [2.2.1.1](#)) with the following attributes.

Client Token	Value
aud	The same URL as the service URL that responded with the challenge (from section 3.1.5.1.1); that is, [Issuer based certificate challenge].SubmitUrl
iat	The current timestamp as described in section 2.2.1.1
nonce	[Issuer based certificate challenge].Nonce

3. The Client Token that was generated in step 2 is signed using **JWS** with an X509 certificate. The Issuer ([\[RFC2459\]](#) section 4.1.2.4) of the certificate MUST be one of the values in [Issuer based certificate challenge].CertAuthorities. If more than one certificate meets this criterion, the choice of which certificate to use is implementation-specific. During signing, JWS headers, as defined in Client Token JWS Headers (section [2.2.1.2](#)), MUST be used.
4. The content that was obtained in step 3 is used as the <Signed-JWT> value in the request that is specified in section [3.1.5.2.1](#).
5. If the client does not have possession of the private key of an X509 certificate that matches the conditions in step 3, the client MUST omit the AuthToken parameter from the request that is defined in section [3.1.5.2.1](#).

3.1.5.3 Thumbprint based certificate challenge response

The server's response is a challenge for proof of possession of a private key for a certificate that is specified by the server, as described in section [3.2.5.2](#). The server's challenge from section [3.2.5.2](#) is

converted into a [Thumbprint based certificate challenge], and a signed **JWT** token is created on the client from the [Thumbprint based certificate challenge], as described in the processing details (section [3.1.5.3.3](#)). The client then responds to the server with a challenge response as defined in section [3.1.5.3.1](#).

Note that a [Thumbprint based certificate challenge], which is used only locally for message processing, is a tuple with the following definition.

```
[Thumbprint based certificate challenge] =  
[  
  CertThumbprint, string;  
  ServerContext, string;  
  Nonce, string  
]
```

3.1.5.3.1 Request

In response to the server's challenge, as specified in section [3.2.5.2](#), the client responds to the server by making an **HTTP** request to the server as follows.

HTTP Request parameter	Value
Method	The same method as the request that was made to the service URL that responded with the challenge (from section 3.1.5.1.1)
URL	The same URL as the service URL that responded with the challenge (from section 3.1.5.1.1)
Header: "Authorization"	PKeyAuth AuthToken="<Signed-JWT>", Context="[Thumbprint based certificate challenge].ServerContext"

Signed-JWT: A Client Token (section [2.2.1.1](#)) that was generated and signed using **JWS**, as specified in the processing details (section [3.1.5.3.3](#)).

3.1.5.3.2 Response

See section [3.2.5.3](#).

3.1.5.3.3 Processing Details

The client processes the server's thumbprint based certificate challenge in the following manner.

1. The client converts the server's challenge into a [Thumbprint based certificate challenge] as follows.

[Thumbprint based certificate challenge] name	Value
CertThumbprint	<cert-thumbprint> (section 3.2.5.2.2)
ServerContext	<Server-state> (section 3.2.5.2.2)
Nonce	<Challenge-nonce> (section 3.2.5.2.2)

2. The client forms a Client Token (section [2.2.1.1](#)) with the following attributes.

Client Token	Value
aud	The same URL as the service URL that

Client Token	Value
	responded with the challenge (from section 3.1.5.1.1)
iat	The current timestamp as described in section 2.2.1.1
nonce	[Thumbprint based certificate challenge].Nonce

3. The Client Token that was generated in step 2 is signed using **JWS** with an X509 certificate. The certificate MUST have the same X509-certificate thumbprint as specified in [Thumbprint based certificate challenge].CertThumbprint. During signing, JWS headers, as defined in Client Token JWS Headers (section [2.2.1.2](#)), MUST be used.
4. The content that was obtained in step 3 is used as the <Signed-JWT> value in the request that is defined in section [3.1.5.3.1](#).
5. If the client does not have possession of the private key of an X509 certificate whose thumbprint matches [Thumbprint based certificate challenge].CertThumbprint, the client MUST omit the AuthToken parameter from the request that is specified in section 3.1.5.3.1.

3.1.6 Timer Events

None.

3.1.7 Other Local Events

None.

3.2 Server Details

3.2.1 Abstract Data Model

None.

3.2.2 Timers

None.

3.2.3 Initialization

None.

3.2.4 Higher-Layer Triggered Events

None.

3.2.5 Message Processing Events and Sequencing Rules

The following processing events and rules apply when the service needs to verify proof of possession of the private key of an X509 certificate on the client, and the client indicated its ability to participate in this protocol using the request semantics specified in section [3.1.5.1.1](#).

Event	Description
Issuer based certificate challenge	A challenge for proof of possession of the private key of any certificate issued by one of a given set of issuers.
Thumbprint based certificate challenge	A challenge for proof of possession of the private key of a specific certificate.
Challenge response	Processing of the challenge response that was received from the client.

Based on the context of the client or the resource being protected, the service will issue either an issuer based certificate challenge (section [3.2.5.1](#)) or a thumbprint based certificate challenge (section [3.2.5.2](#)). This determination is implementation-specific.

3.2.5.1 Issuer based certificate challenge

The server issues this challenge if it must verify proof of the client's possession of the private key of any X509 certificate that was issued by a set of trusted issuers.

3.2.5.1.1 Request

See section [3.1.5.1](#).

3.2.5.1.2 Response

The server issues a challenge using an **HTTP** response with the following characteristics.

HTTP response	Value
Response code	302 Found [RFC2616]
Header: Location	urn:http-auth:PKeyAuth?Nonce=<Challenge-nonce> &CertAuthorities=<cert-authorities>&Version=1.0 &SubmitUrl=<Submit-url>&Context=<Server-state>

Challenge-nonce: A short-lived nonce.

cert-authorities: A semicolon-delimited list of URL-encoded issuer names. The client must prove possession of the private key of a certificate that was issued by one of these issuers.

Submit-url: The URL to which the client MUST submit its response to the server's challenge. The server uses the same URL to which the client submitted its request (section [3.1.5.1.1](#)).

Server-state: Context information that the client will play back to the server to complete this protocol sequence. This information is in the form of opaque binary data that cannot be deciphered by the client.

3.2.5.1.3 Processing Details

None.

See section [5.1](#) for security considerations.

3.2.5.2 Thumbprint based certificate challenge

The service issues this challenge if it must verify proof of the client's possession of the private key of a specific X509 certificate.

3.2.5.2.1 Request

See section [3.1.5.1](#).

3.2.5.2.2 Response

The server issues a challenge using an **HTTP** response with the following characteristics.

HTTP response	Value
Response code	401 Unauthorized [RFC2616]
Header: WWW-Authenticate	PKeyAuth Nonce="<Challenge-nonce>", Version="1.0", CertThumbprint="<cert-thumbprint>", Context="<server-state>"

Challenge-nonce: A short-lived nonce

cert-thumbprint: Thumbprint of the X509 certificate. The client needs to prove possession of private key of this certificate.

Server-state: Context information that the client will play back to the server to complete this protocol sequence. This information is in the form of opaque binary data that cannot be deciphered by the client.

3.2.5.2.3 Processing Details

None.

See section [5.1](#) for security considerations.

3.2.5.3 Challenge response processing

When the server receives a challenge response from the client, it processes the responses as described in the following sections.

3.2.5.3.1 Request

The request is a challenge response from the client, as defined in section [3.1.5.2.2](#) and section [3.1.5.3.2](#).

3.2.5.3.2 Response

After processing the challenge response, the server can determine whether the proof presented by the client meets its requirements. The response from the service, regardless of whether the challenge response met its criteria, is implementation-specific.

3.2.5.3.3 Processing Details

When the server receives the challenge response, the server SHOULD perform the same checks that it performed to determine whether to issue an issuer based or thumbprint based certificate challenge (section [3.2.5](#)).

If the request contains an Authorization header that has an AuthToken parameter, the server uses all of the following criteria to verify the client's proof of possession of the appropriate private key.

- The Signed-JWT parameter that was generated in section [3.1.5.2.1](#) or section [3.1.5.3.1](#) has a valid signature according to the JWS specification.
- The Signed-JWT parameter contains the JWS headers specified in section [2.2.1.2](#).

- The x5c attribute of the JWS headers contains an X509 certificate that meets the proof of possession criteria for this server request.
- [Client Token].nonce (section [3.1.5.2.3](#) or section [3.1.5.3.3](#)) is the same as the nonce specified in the challenge (section [3.2.5.1.2](#) or section [3.2.5.2.2](#)).
- [Client Token].aud is the same as the URL that is being requested.

If the request contains an Authorization header, but no AuthToken parameter, the server can conclude that the client does not have an X509 certificate that meets the server's criteria.

If the request does not contain an Authorization header, the server MUST evaluate the client for a challenge as specified in section [3.2.5.1](#) or section [3.2.5.2](#).

3.2.6 Timer Events

None.

3.2.7 Other Local Events

None.

Note Throughout these examples, the fictitious names "client.contoso.com" and "server.contoso.com" are used.

4.1.1 Client Request

```
GET /adfs/ls/?wa=wsignin1.0&wtrealm=https://client.contoso.com/&wreply=https://client.contoso.com/ HTTP/1.1

User-Agent: Mozilla/5.0 (compatible; MSIE 8.0; Windows NT 6.1; Trident/4.0);PKvAuth/1.0
```

The following shows an example of a successful server response in PKAP.

HTTP/1.1 302 Found

Location: urn:http-auth:PKKeyAuth?SubmitUrl=https%3A%2F%2Fserver.contoso.com%2F&nonce=z89m3ZKTA3cg8l9N3khitA&Version=1.0&Context=AAEA
AEZ2vfj-laYaqWZKsOae3sJjkmyeLZOBuDF76aU-
vbUwWwQS_g77_WWawrxSdaDxeYte_sNevuvsot1Y6V82XPwnmi5TaNeFBbeoxDzpa6jf2KDSNIXP8wewsEJi19l-
cb2ETdqUih3GBN2spsQkGRzKZgeycOsV0V1A7JNCQGa5QUHCoMa9Q9vK7ZRLvXXUC7U9o9Npdlp_fAbsXNWD-
4f7AeezaFgK3Nnyrlmgtptxn45BWODrZg3RgnCogX31t9grL9tnNbYHQnzsy479qWpH40LoRoY2bmXtJ1FNKVsdtNx-
iQQckFts5A_yHmBd5GjOf14fx0WALt1PeVYOBDsKfeZ1EXLnAYsNM0s4wXSBZNALBfAJYlbiga4Y5hPKgABAAcO4R-
vln4Z-aBAE8_vOCTa_Y4fg9Ctm941tzjgVjC6clMLGHJyeeUxGaog6xo1h4SnGJiYzi5NF-
OMMO77oiIdpmncJSHJEftswMlX5A7H5Avf0hrFaVoA7SKiz_aSR-YdxQ9VSC1JS-
8PlDFgXiHlBG1QEX4FtSN8Nm9izF52--
E6Sovge5M9aHvQdY3IVcyJJ3QzclckLYLKZN_2UJunG7uI8DvCp5u5hxuwxdbpwQVcdP5gtMURGLE9wQ97S0vuP-
MC-Flu7m-W4887fSNLS5Hu65j09BQxxOqT7JB7pe0xYzCJg-534rOr-
UyhWDXNh5dww85AlFXq00YwUHElykYAAAAEgcSOCQUPUel5FWtQ2XzLn--k-
0_55xfN3drjvYIyudu0kpMlMbjBRXQsHerZwnkA3nuuJRDQVksotQ90PP_eRgSpEZr8cl7OVclORi8uX4qdIXc6Q
A4pK5hrD2vyWwA&CertAuthorities= OU%253Df15cd533-92fa-4d96-8b69-
aa2d0c2f1d7%252CCN%253DMS-Organization-
Access%252CDC%253Dserver%252CDC%253Dcontoso%252CDC%253Dcom%2b

The following shows an example of a successful client response to the server challenge in PKAP.

```
GET /adfs/ls/?wa=wsignin1.0&wtrealm=https://client.contoso.com/&wreply=https://client.contoso.com/ HTTP/1.1

Authorization: PkeyAuth
AuthToken="eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiIsIng1eWYiOiJmYXNUSU1FVURDQ0F6aWdBd0lCQWdJUVF4QXk1Yk1kOj0PSVdqdjA1bWbWJlYmpBTKna3Foa21tHOxcwQkFRc0ZBREncCcURHqNbUQVJCZ29Ka211hSmsvSXNAQVUaRmdOamIyMhDGpVlLQ1pJbWlaUHMlMR1FCR1JZS2JuUjBwAE4wTUJVR0NnbVNBKb21UOG14a0FsaIdCMU5EVfMRXVF6RXDGd11LQ1pJbWlaUHMlMR1FCR1JZSmJXbGpjb1t16YjJAME1CMEdBMVVFQXhN1V1RWXRUM0puWVvc1cGVtRjBhVz11TFVGAlkyVnpjekfYQmdOVk1C1RKR114Tld0a05UTXpMVGt5Wm1fde5HUTVOaTA0WWpZNUxXrMhNbVF3WxpKb1U1UZGtOekElRncweE5UQX1NRGN3TURBe1UrmFGdzB51RbE1UEUXNREv4TVRGYU1DOHhMVEfYQmdOVBtJTRVTKR11ElWkdNek5EZ3pMVGc0TURrd5EZ3ZnaTfFoT0daakXzRmpOekJrT0RVNU1UZ3hNRENDQVNjQ1RRWUvLb1pJAHZjTkJFRRUJCUFEZ2dFaeFQ2QNBW9DZ2dFQkFKU0h4UEXiRXB1a1BVbm9Rc2hFZVB1b3VldjR6U2NKVYsUWVoaFBDbWFPVSVZ6aExwdExwE2d2ccGc3SVE2SU1kbHFFpJNxeWJYZ1V0eDNXVY3d1RCRTZmURKcRvrdKJRZfhhRFFjUHA44bGhmZjYGVm1qSFVpT1A4a3VMUET4c1Z5dFZJVF51c1pXczdwekhtdXdoag9xcFivNd0WdzdUw3crtUx0dEFBS11OVDdsYXhuSUU
```


SubmitUrl="https://server.contoso.com:443/adfs/oauth2/token/",nonce="MgiWURGrAgFPdYcHU0x7A",Version="1.0",Context="AABAAE4M2mL2uEHypDzKAv1e1mWF45YfXgWfcQzJz0H8hts9Cigre4f5xbnF75bLokLRZiplN2ht8PHq56m4CoJqWwOIlubHceZKcKU92_otnQ3NJDZHXKvNj4e4QTq9BuLfL0nVrenxHW2w6183adr6K9TDvkni03XnnL8fs7xH9ybpy7W5ArwBta3WOXMAai4ryiMMDSFP20lnq4yEK8XSvZPGZuc3QIntqfc20w9-BnuyquiQpYgdvXhHqBfiwue68VLcmLakURlqmYvq40s_H2W_7vDlhJQEnlqXwcc3wL3fCvo81LmqG2dKTrtMsqWXO-HqZOR3DGcx10i29DfsKfEz1EXLnAYsNM0s4wXSBNALBfAJYlbiga4Y5hPKgABAAcdGfgHpxUV_kX-dvZQhd-HmNffvzatZdYgYtmRD5NdKAhqKh6rqJ0x5GyoXDJ1QFYAE7ZDvuUzXOnx7acv3EUx6z-MSEyNyCaHbq5B_1NBPuSLA9m9vBvGCPeSgJUFuXi0uZmTrXJ_gjhkmIR_qtRgeK33V6s0N0IOeL8Ve9sbpIFhlk-FjaARruVBuHHzjpxwoKHG0NbK5--nY-v5mXeK8d-fvXVPwqEk9CkOzNaCIPN4Pn-Q_bGNnfnOBU14j4z5YirH0uuz0NDR8xFonoNaTRJpQSErSk71M6TvyqHxtzjD7adw_XnPG-ojpXEI39ccsbr2ndt4f5VqHzSYAAAAH3S327bGuepWQA8jSmgrWIGsAMdNkld1SadT-vB7gvNmw9ETFeAwjcndeiAnAK328_aYg2Xn7f_XFBdl1u5vMZ-XYPOT2sgLbW_Ykks-wascZ7iRn9IXufu8c7Ymi00uw",CertThumbprint="A74F3CE065D87A12149FB2C0DC492D0C99580BD3"

AauthToken="eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiIsIng1YyI6WyJNSU1FVURDQ0F6aWdBd0lCQWdJUU4ZU1sYsYk1oeDZa3dLSTE0Z0h6aERBTkJna3Foa2lHOXcwQkFrc0ZBREncCUHRQnBUQVJCZ29Ka2l1hSmsvSXNAQUVaRmdOamIyMHdGQVlLQ1pJbWlaUHM1MR1FCR1JZR2JuUjBwAEw4TUUJVR0NbnVKNb2l1UG01a4oFSaIdCmU5EVFMxRVf6RXdGd11Q1pJbWlaUHM1MR1FCR1JZsMxJbGpjb1T6YjJmE1CEMDBMVVFQXhNv1RWTXRUM0puWz1cGVTRjBhVz11TFVGA1kyVnpjkeFyQmdOVkBC1RKR1l4Tl40a05UTXpMVGt5Wm1FdE5HUTVOaTA0WWpZNUxXRmNbVf3WXpKbU1UZGtOekFlRncweE5UQXlNRGN3TURNME5UZGFGdZB5T1RBeU1EUUXdNRFewT1RkYU1DOHhMVEFyQmdOVkBJbTRVRKREk1TVdZNU1UZFtFMFEQ4Xprde5ERTRaafTFpTdVkaExXVml0ak13TwpnNU1qWmlaRENDQVNjZD0RRWUpLb1pJaHJz1tkFRRUJCUFFT22DFUEFQZNBUNW9DZ2dGfQLeMlBTvK1X0vpsaDBH20Q5WgZUFZpb3hla21Mw1Rh9QNMUxdidkKzVqXVj3b21ua1MzRfSdSQXpoUFNQVTNSNWNazkpNzKJHZHJ3N1JCS2tQTEFJRitEQnc5blF5L1YxSnk5bEtJRWlaYUwrbDhDSNfxRk9jZUluWGPxWnJPWC8yM3ppUTBYK01Ubs9JcU1zRjg4U2FGN2Ezb04wQ1ZMa21PaU1lQkFXNXW50L0FucilUWXNVWGN2YmZreXRPnWFGcVzqPjBgc2VpUUIjciFJJMXR6SVdIS2kweWRKWwPIdDlB3NSaHhaUG9YQmwyRnV4U2VMRnNpYj15ZD0d0Nab1Rad30ek02TD2pTMVvQWwhKLZRN1lHMEp5U1lqUUVz3U15aWpsN0hNvM6RdUk2UZWlam1SZtUN1QRzKdHZT1eHJ6L3NFZXJ4V1t1tRmZ1adJwCHNDQxdGfQFhT013VENCNmpBTUjnt1Z1Uj1CQWY4RUFGUQFNG1lHQTFVZEprRU1vd1FNTUfVrRONDc0dBUVVGQndNQ01CEMDBMVVKRGdRV0JCuz1rMHFKSUxOMXpwSlA4Kzk1RE4vcitJWVVoakFpQmdzcWhraUc5eFFCQ11JY0FRUVRCSUVREt1RkUEXd05rMFC5R2F3NWdooEPmakFpQmdzcWhraUc5eFFCQ11JY0FnUVRCSUVRT1pFzktUbEJqMED4dXV0akFva212VEFPQmdzcWhraUc5eFFCQ11JY0F3UVRCSUVRA09BaHpsGmhJRUDuc103RVJwci9tekFpQmdzcWhraUc5eFFCQ11JY0JBUVRCSUVR1p1Z1ZYdVZCvME85ZDfNWfpQWxzeekFpQmdzcWhraUc5eFFCQ11JY0J3UUVCSUVCTURBTkJna3Foa2lHOXcwQkFrc0ZBQU9DQVFFQVUvTkpmTFfLOWDVGSGkIrcDF0OG43YkJRHRVRBdy9yQnRXN1l1hRWRZSmhJAZVMTHJJOW5HYUvXTHI4VzdFeVbOMWExU3paQ3g1bGxxL1lEbEhoNVp0dUlnSXpncl1BdXAX2R3N5MRhmR121b1hNkZVtmMLNZ00YXA4EaBuzQRk5SZjUxNVf6VGSya0pLeGdRk0RXTkcl1TWkz3Q2znVKQWdYRUFLMhRH1hqb2FpVnmLML2SDZFVvUkFCE5Fual9NS2hQ2NGNUNxRnKRrXlHZEYRyWEM3M13REsYnZJqeEpycTFwY3RpSTB1V1VtQTBcamlMwFR1TE10NkcxBCtIRU1rbzJCZkZ0V09RRHZNekXQcXZESG5McFZSKzZFwmlpBfhnYUZZUjDBS1NEUHFbaE9YwK9JQnhrYUWUdENXL3A3bXfWsklxOWxFNm1hQ2t1ckpWSH1PUT09I119.eyJub25jZSI6Ikt1aVNdVkd0c2kFfUfBkWWN1U94N0EiLCJhdWQioiOiJodHRhZnZovLmZ1ZLNnJbSlkyZUubnR0ZXN0LmlpY3Jvc29mZC5jb2V6NDQndL2FkZnMvb2J1dGgyL3Rva2VUkF5SiEmlhdDk1cMTQyYmZ1Z0tKwOX0.Z0zubeqnaCvOTpJSL7j3BarR1dPsR7Iqe4nlw0HnASn00X7ebPqwjfnVC0Clr1o4qxBnoDWG5mr6EA_09TyjPVqgwly07BA1s-y9v9Q4otkfXpWi_MfAORRZE3dgmHbxYfGonY2oIzRalh8vmmDnRfwbMbH1CUWV7tEOVgePjMnmy68CUGUKPJ7-x99ghGQqOGvPyjBAWXocX3I4adml1fMY6qEfVm_BA07C55ruLUYtYGeJec9w8fEazyXE4ADid1oADH2Cu5jEicB9y3rI54emEUMepy6qfKzncD9DKERNdqVrQZ0G-sb8wjQtskNk5Doga612TFZYGACFR5w", Context="AAEEA4Mz8ml2uEHYDiZkAvI1elMWF45YfXgWfcQzJzOH8hts9Ciqre_4f5xbnf75bLokLRZiplNZht8PHq56m4CoJQWOWIluobHceZKcKU92_otNQ3NJDZHXKvJhe4QTq9BuLfLOnVrenxHW2w6183adr6K9TDvknio3XnnL8fs7xH9ybpj7W5_ArWta3WOXMa14ryiNMDPS20lnQ4YEK8XSVZPGZuzG3UIInIqfc20w09-BnuuyqiQpYgdwvHhqbfiuwe68VLcmclakURlmgYvg40s_H2W_7vDlhJQEnlqXwcc3wL3fCv081LmqG2dKTrtMsqWXOHqZoOR3DGcx10i29DfsKfeZ1EXLnAYsNM0s4wXSBZNALBfAJYlbiga4Y5hPKgABACDgfgHpxUV_kX-dvZQhd-HmNffvzatdJGytmrDo5NdKAH9khH6rqJ0x5GyoXDJlQFYAE7ZDvuUZXonx7acv3tEUX6z-MSEyNYoCaHbq56_1BNPusLjaMgvr9BvGCePosGJUfXi0uZmTRwJj_hjkmIR_qtRgeK33V6BsoN0IOeL8VE9sbpIFh1k-fJAARrUvBuH21pxwKHG0NBK5--nY-v5mXek8d-fVxVPwQEK9Ck0ZaNICPNaPh-

Q_bGNNfnOBu14j4z5YirH0uuzoNDR8xFonoNaTRJpQSErsK7lM6TVqyHxtzjD7adw_XnPG-
o_jpXEI39ccsbR2ndtf5VqHzzSYAAAAHZS327bGuepWQA8jSmgrWIGsAMdNKd1SAdt-
Vb7gvQNmw9ETFeAWCjndeiAnAK328_aYg2Xn7f_XFBd1iu5vMZ-XPOT2sgLbW_Ykks-
wascZ7iRn9IXufu8c7Ymi00uw"

grant_type=refresh_token&refresh_token=7Cn3mdR

5 Security

5.1 Security Considerations for Implementers

The server should ensure that the nonce that it generates is short-lived, and cannot be used by any client after a short period of time. [<1>](#)

5.2 Index of Security Parameters

None.

6 Appendix A: Product Behavior

The information in this specification is applicable to the following Microsoft products or supplemental software. References to product versions include updates to those products.

The terms "earlier" and "later", when used with a product version, refer to either all preceding versions or all subsequent versions, respectively. The term "through" refers to the inclusive range of versions. Applicable Microsoft products are listed chronologically in this section.

The following table shows the relationships between Microsoft product versions or supplemental software and the roles they perform.

Windows Server releases	Client role	Server role
Windows Server 2016 operating system	No	Yes
Windows Server operating system	No	Yes
Windows Server 2019 operating system	No	Yes
Windows Server 2022 operating system	No	Yes
Windows Server 2025 operating system	No	Yes

Exceptions, if any, are noted in this section. If an update version, service pack or Knowledge Base (KB) number appears with a product name, the behavior changed in that update. The new behavior also applies to subsequent updates unless otherwise specified. If a product edition appears with the product version, behavior is different in that product edition.

Unless otherwise specified, any statement of optional behavior in this specification that is prescribed using the terms "SHOULD" or "SHOULD NOT" implies product behavior in accordance with the SHOULD or SHOULD NOT prescription. Unless otherwise specified, the term "MAY" implies that the product does not follow the prescription.

[<1> Section 5.1](#): Windows Server 2016 and later validate that the nonce provided by the client was issued at a time not more than seven minutes before the current system time of the server evaluating it.

7 Change Tracking

This section identifies changes that were made to this document since the last release. Changes are classified as Major, Minor, or None.

The revision class **Major** means that the technical content in the document was significantly revised. Major changes affect protocol interoperability or implementation. Examples of major changes are:

- A document revision that incorporates changes to interoperability requirements.
- A document revision that captures changes to protocol functionality.

The revision class **Minor** means that the meaning of the technical content was clarified. Minor changes do not affect protocol interoperability or implementation. Examples of minor changes are updates to clarify ambiguity at the sentence, paragraph, or table level.

The revision class **None** means that no new technical changes were introduced. Minor editorial and formatting changes may have been made, but the relevant technical content is identical to the last released version.

The changes made to this document are listed in the following table. For more information, please contact dochelp@microsoft.com.

Section	Description	Revision class
6 Appendix A: Product Behavior	Added Windows Server 2025 to the list of applicable products.	Major

8 Index

A

Abstract data model
[client](#) 10
[server](#) 14
[Applicability](#) 7

C

[Capability negotiation](#) 7
[Change tracking](#) 24
Client
 [Abstract data model](#) 10
 examples
 [interactive request](#) 18
 OAuth token request
 [refresh token request](#) 19
 [response](#) 20
 [Higher-layer triggered events](#) 10
 [Initialization](#) 10
 [Message processing events and sequencing rules](#) 10
 [Other local events](#) 14
 [Timer events](#) 14
 [Timers](#) 10
[Complex type definitions](#) 8

D

Data model - abstract
[client](#) 10
[server](#) 14

E

Examples
[interactive request](#) 18
[overview](#) 18

F

[Fields - vendor-extensible](#) 7

G

[Glossary](#) 5

H

Higher-layer triggered events
[client](#) 10
[server](#) 14

I

[Implementer - security considerations](#) 22
[Index of security parameters](#) 22
[Informative references](#) 6
Initialization
[client](#) 10
[server](#) 14

Interactive request examples
[client request](#) 18
[client response](#) 18
[server challenge response](#) 18
[Introduction](#) 5

M

Message processing
 client
 [initial request](#) 10
 [issuer-based certificate challenge](#) 10
 [thumbprint-based certificate challenge](#) 10
 server
 [challenge response](#) 14
 [issuer-based certificate challenge](#) 14
 [thumbprint-based certificate challenge](#) 14
Messages
[complex data types](#) 8
[transport](#) 8

N

[Normative references](#) 6

O

OAuth token request examples
 client
 [refresh token request](#) 19
 [response](#) 20
 [server challenge response](#) 19
 Other local events
 [client](#) 14
 [server](#) 17
[Overview \(synopsis\)](#) 6

P

[Parameters - security index](#) 22
[Preconditions](#) 7
[Prerequisites](#) 7
[Product behavior](#) 23
Protocol examples
 [interactive request](#) 18
[Protocols – relationship to](#) 7

R

References
[informative](#) 6
[normative](#) 6
[Relationship to other protocols](#) 7

S

Security
 [implementer considerations](#) 22
 [parameter index](#) 22
Sequencing rules
 [client](#) 10

[server](#) 14
Server
 [Abstract data model](#) 14
 examples - challenge response
 [interactive request](#) 18
 [OAuth refresh-token redemption](#) 19
 [Higher-layer triggered events](#) 14
 [Initialization](#) 14
 [Message processing events and sequencing rules](#)
 14
 [Other local events](#) 17
 [Timer events](#) 17
 [Timers](#) 14
[Standards assignments](#) 7

T

Timer events
 [client](#) 14
 [server](#) 17
Timers
 [client](#) 10
 [server](#) 14
[Tracking changes](#) 24
[Transport](#) 8
Triggered events
 [client](#) 10
 [server](#) 14

V

[Vendor-extensible fields](#) 7
[Versioning](#) 7